

IT-SIMPLERA INSTITUTE

Cyber Security Department



Cyber Security Analyst Internship Program

FINAL PROJECT

Secure the Range: End-to-End Cybersecurity Assessment

Client: Nimbus Retail Co.

Prepared By: Zaid Qazi

Submitted To: Talal Rehan

Department: Cyber Security

Submission Deadline: 24 August 2026

Table of Contents:

- Executive Summary
- Scope & Methodology
- Phase 1 – Foundations & Network Design
- Phase 2 – Reconnaissance & OSINT
- Phase 3 – Enumeration & Scanning
- Phase 4 – Vulnerability Assessment
- Network Architecture Diagram
- Vulnerability Findings
- Risk Matrix
- Cryptography & TLS Review
- Remediation Recommendations
- Incident Response Plan
- Conclusion
- References
- Appendix – Screenshots & Scan Logs

Phase 1 – Foundations & Network Design

Q1. Analysis of Recent Real-World Cybersecurity Breaches

Three Real-World Security Breaches

1. Change Healthcare Cyberattack – 2024

CIA Triad Violated: Confidentiality and Availability

In 2024, Change Healthcare suffered a major ransomware cyberattack that resulted in a breach of protected health information and caused widespread disruption across the U.S. healthcare system. Confidentiality was violated because sensitive patient information was compromised. Availability was also affected because healthcare organizations experienced disruption to critical services and payment operations. This incident demonstrates how ransomware can affect both sensitive information and business operations.

HHS later reported that approximately **192.7 million individuals** were impacted.

2. Ticketmaster Data Security Incident – 2024

CIA Triad Violated: Confidentiality

In 2024, Ticketmaster discovered unauthorized activity involving an isolated cloud database hosted by a third-party data services provider. The database contained customer information including email addresses, phone numbers, encrypted credit card information, and other personal information. This primarily violated confidentiality because unauthorized individuals gained access to customer data. The incident also demonstrates the security risks associated with third-party cloud infrastructure.

Ticketmaster confirmed the incident and stated that its customer account system itself was not affected.

3. 23andMe Data Breach – 2023

CIA Triad Violated: Confidentiality

In 2023, attackers used credential stuffing against 23andMe accounts using credentials obtained from previous unrelated breaches. Unauthorized access exposed sensitive personal information belonging to affected users, including information associated with ancestry and genetic services. This was primarily a confidentiality violation because private user information became accessible to unauthorized parties. The incident highlights the importance of strong authentication, monitoring, and protection against reused credentials.

The UK Information Commissioner's Office later found that personal information belonging to **155,592 UK residents** had been accessed and fined 23andMe £2.31 million.

Small CIA Summary Table

Incident	Year	Confidentiality	Integrity	Availability
Change Healthcare	2024	✓	-	✓
Ticketmaster	2024	✓	-	-
23andMe	2023	✓	-	-

Q2. Secure Network Design for Nimbus Retail Co.

Secure Small-Office Network Design

Nimbus Retail Co. requires a secure and segmented network for its e-commerce environment. The proposed architecture uses a router, firewall, managed switch, separate internal subnets, a web server, and a database server. Network segmentation is used to reduce unauthorized access and limit the impact of a potential security breach.

IP Addressing Plan

Network/Device	IP Range / Address	Purpose
Employee LAN	192.168.10.0/24	Employee computers
Server Network	192.168.20.0/24	Internal servers/database
Web Server / DMZ	192.168.30.10	Public e-commerce web server
Database Server	192.168.20.10	Stores application/customer data
Firewall	192.168.10.10	Controls network traffic
Router	Public/WAN	Internet connectivity

Structure:

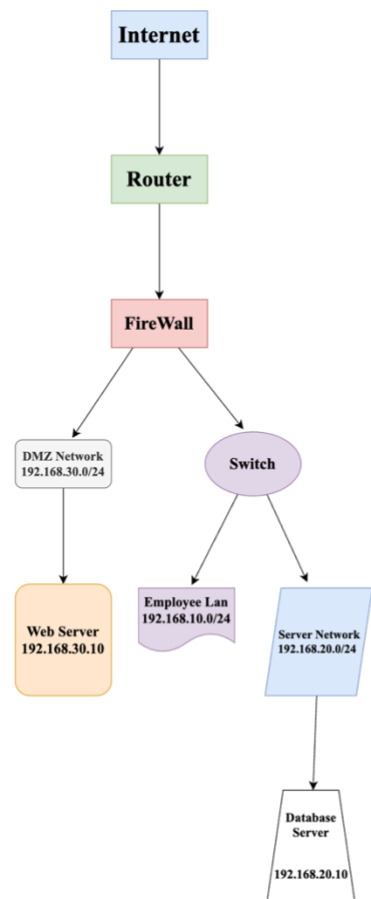


Figure 1: *Proposed Secure Network Architecture for Nimbus Retail Co.*

The network is segmented to separate systems according to their security requirements. Employee workstations are placed on the 192.168.10.0/24 subnet, while sensitive internal servers are placed on the 192.168.20.0/24 subnet. The public-facing web server is isolated in a DMZ using the 192.168.30.0/24 network.

The firewall controls communication between these network segments. Internet users should be able to reach only the required web services on the web server. Direct Internet access to the database server should not be permitted. Only necessary communication from the web/application environment to the database should be allowed. This segmentation reduces the possibility that compromise of one system will provide unrestricted access to the rest of the network.

Q3. “Buy Now” Action Through the 7 OSI Layers

Customer “Buy Now” Action Through the OSI Model

When a customer clicks the “Buy Now” button on the Nimbus Retail Co. e-commerce website, the request travels through the network using different functions represented by the seven layers of the OSI model.

Layer	Name	“Buy Now” What Happens
7	Application	The customer's browser sends an HTTPS request to the e-commerce web application to process the purchase.
6	Presentation	The data is formatted and protected using encryption such as TLS.
5	Session	The communication session between the customer's browser and the server is established and maintained.
4	Transport	TCP provides reliable delivery of data. HTTPS normally uses TCP port 443 .
3	Network	IP addresses and routing are used to send packets from the customer's device to the web server.
2	Data Link	Data is organized into frames and transferred across the local network using technologies such as Ethernet or Wi-Fi.
1	Physical	The data is transmitted as bits through physical media such as Ethernet cables, fiber, or wireless signals.

Simple Flow

Buy Now → HTTPS Request → TLS Encryption → TCP → IP → Ethernet/Wi-Fi → Physical Transmission

Each OSI layer performs a different function to deliver the customer's "Buy Now" request securely and reliably from the device to the Nimbus Retail Co. web server.

Q4. Access Control Policy for Nimbus Retail Co.

Purpose

The purpose of this policy is to ensure that employees of Nimbus Retail Co. have access only to the systems, applications, and information required to perform their job responsibilities. This policy follows the **Principle of Least Privilege (PoLP)** to reduce unauthorized access and protect sensitive company and customer information.

1. User Access

Every employee must have an individual user account. Shared user accounts should be avoided. Access to company resources must be provided according to the employee's job role and department.

2. Least Privilege

Employees must receive only the minimum permissions necessary to perform their assigned duties. For example, Sales employees should not have access to sensitive HR or Finance information unless there is a legitimate business requirement.

3. Role-Based Access

Access permissions should be assigned through security groups based on job roles and departments. HR, Finance, Sales, IT, and Management should have separate access groups.

4. Administrative Access

Administrator privileges must be limited to authorized IT personnel. Normal employees should not receive administrator rights unless specifically required and approved.

5. Authentication Security

Employees must use strong passwords and follow the organization's password policy. Multi-factor authentication (MFA) should be enabled for sensitive and privileged accounts where available.

6. Sensitive Data

Customer, financial, employee, and other confidential information must be accessible only to authorized personnel. Sensitive information should be protected both during transmission and while stored.

7. Access Reviews

User accounts, group memberships, and permissions should be reviewed regularly. Unnecessary or excessive permissions must be removed.

8. Employee Role Changes

When an employee changes department or job responsibilities, their permissions must be updated according to their new role. Access that is no longer required must be removed.

9. Employee Termination

When an employee leaves Nimbus Retail Co., their account and access to organizational systems must be disabled or removed promptly according to company procedures.

10. Monitoring

Access to sensitive systems and information should be logged and monitored. Suspicious or unauthorized access attempts should be investigated by the security team.

Conclusion

This access control policy helps Nimbus Retail Co. protect its systems and sensitive information by ensuring that users receive only the access required for their responsibilities. Applying least privilege, role-based access, strong authentication, regular access reviews, and monitoring reduces the risk of unauthorized access and data breaches.

Phase 2: Reconnaissance & OSINT

Q5. OSINT Reconnaissance

Introduction

Open-Source Intelligence (OSINT) techniques were used to gather publicly available information about the selected lab target, **tryhackme.com**. The reconnaissance process included WHOIS lookup, Google dorking, certificate transparency logs, and publicly available social media information. The objective was to identify useful information about the target without exploiting or gaining unauthorized access to any system.

5.1 WHOIS Lookup

Command Used:

```
whois tryhackme.com
```

Findings:

The WHOIS lookup revealed registration and DNS information about the target domain. The domain **tryhackme.com** is registered through **NameCheap, Inc.** and was created on **July 5, 2018**. The record shows an expiry date of **July 5, 2034**. The domain uses Cloudflare name servers, including **KIP.NS.CLOUDFLARE.COM** and **UMA.NS.CLOUDFLARE.COM**.

```
(zaid@kali)-[~]
$ whois tryhackme.com
Domain Name: TRYHACKME.COM
Registry Domain ID: 2282723194_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2025-05-11T14:06:02Z
Creation Date: 2018-07-05T19:46:15Z
Registry Expiry Date: 2034-07-05T19:46:15Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransf
erProhibited
Name Server: KIP.NS.CLOUDFLARE.COM
Name Server: UMA.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wi
cf/
>>> Last update of whois database: 2026-08-13T19:09:20Z <<<

For more information on Whois status codes, please visit https://icann.org/ep
p
```

Figure 2: WHOIS reconnaissance results for tryhackme.com

5.2 Certificate Transparency Logs

Certificate Transparency logs were analyzed to identify publicly visible subdomains associated with tryhackme.com. The results revealed multiple subdomains, including auth.tryhackme.com, careers.tryhackme.com, store.tryhackme.com, access.tryhackme.com, vpn.tryhackme.com, labs.tryhackme.com, and help.tryhackme.com. Certificate Transparency logs are useful during passive reconnaissance because they can reveal publicly issued certificates and associated domain names without directly interacting with the target systems.

crt.sh

Identity Search

CSV

JSON

Group by Issuer

Criteria

Type: Identity

Match: ILIKE

Search: 'tryhackme.com'

Certificates	crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
	28763144264	2026-08-12	2026-08-12	2027-02-25	squawker-vpn.vm.tryhackme.com	squawker-vpn.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28756557828	2026-08-12	2026-08-12	2027-02-25	bug-validator.vm.tryhackme.com	bug-validator.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28704346024	2026-08-10	2026-08-10	2026-11-08	auth.tryhackme.com	auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28784350612	2026-08-10	2026-08-10	2026-11-08	auth.tryhackme.com	auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28701542678	2026-08-10	2026-08-10	2026-11-08	auth.tryhackme.com	auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28700934647	2026-08-10	2026-08-10	2026-11-08	auth.tryhackme.com	auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28701596077	2026-08-10	2026-08-10	2026-11-08	auth.tryhackme.com	auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28696835283	2026-08-10	2026-08-10	2026-11-08	setup.auth.tryhackme.com	setup.auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28695964865	2026-08-10	2026-08-10	2026-11-08	setup.auth.tryhackme.com	setup.auth.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28691730501	2026-08-10	2026-08-10	2027-02-23	*.cell-prod-eu-west-3b.vm.tryhackme.com	*.cell-prod-eu-west-3b.vm.tryhackme.com *.novnc.cell-prod-eu-west-3b.vm.tryhackme.com *.reverse-proxy.cell-prod-eu-west-3b.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28689539583	2026-08-10	2026-08-10	2027-02-23	*.cell-prod-eu-west-3a.vm.tryhackme.com	*.cell-prod-eu-west-3a.vm.tryhackme.com *.novnc.cell-prod-eu-west-3a.vm.tryhackme.com *.reverse-proxy.cell-prod-eu-west-3a.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28689470514	2026-08-10	2026-08-10	2027-02-23	*.cell-prod-eu-west-3c.vm.tryhackme.com	*.cell-prod-eu-west-3c.vm.tryhackme.com *.novnc.cell-prod-eu-west-3c.vm.tryhackme.com *.reverse-proxy.cell-prod-eu-west-3c.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28689443903	2026-08-10	2026-08-10	2027-02-23	*.cell-prod-eu-west-3b.vm.tryhackme.com	*.cell-prod-eu-west-3b.vm.tryhackme.com *.novnc.cell-prod-eu-west-3b.vm.tryhackme.com *.reverse-proxy.cell-prod-eu-west-3b.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28550839065	2026-08-05	2026-08-05	2026-11-03	careers.tryhackme.com	careers.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28550854112	2026-08-05	2026-08-05	2026-11-03	careers.tryhackme.com	careers.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28532953672	2026-08-04	2026-08-04	2027-02-17	bug-validator.vm.tryhackme.com	bug-validator.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M01
	28411410904	2026-07-31	2026-07-31	2026-10-29	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28411414216	2026-07-31	2026-07-31	2026-10-29	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28370380909	2026-07-30	2026-07-30	2027-02-12	access.vm.tryhackme.com	access.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M04
	28370270084	2026-07-30	2026-07-30	2027-02-12	access.vm.tryhackme.com	access.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M04
	28355860686	2026-07-29	2026-07-29	2027-02-11	vpn.vm.tryhackme.com	vpn.vm.tryhackme.com	C=US, O=Amazon, CN=Amazon RSA 2048 M04
	28348034059	2026-07-29	2026-07-29	2026-10-27	labs.tryhackme.com	labs.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28348029910	2026-07-29	2026-07-29	2026-10-27	labs.tryhackme.com	labs.tryhackme.com	C=US, O=Let's Encrypt, CN=YR1
	28329859147	2026-07-28	2026-07-06	2026-10-04	help.tryhackme.com	help.tryhackme.com	C=US, O=Google Trust Services, CN=WE1
	28328644567	2026-07-28	2026-07-28	2026-10-26	tryhackme.com	*.pages.tryhackme.com pages.tryhackme.com	C=US, O=Google Trust Services, CN=WE1

Figure 3: Certificate Transparency results for tryhackme.com

5.3 Google Dorking

Google dorking was used to identify publicly indexed pages associated with the target domain. The site: operator was used to restrict search results to tryhackme.com, while the inurl: operator was used to identify pages containing specific keywords in their URLs.

Queries Used:

site:tryhackme.com

site:tryhackme.com inurl:login

Findings:

The first query revealed multiple publicly indexed pages belonging to TryHackMe. The second query identified the publicly indexed TryHackMe login page. These results demonstrate how search engine operators can be used during passive reconnaissance to discover publicly available web resources without directly scanning the target.

The screenshot shows a Google search interface with the query `site:tryhackme.com` entered in the search bar. The results are displayed under the 'All' tab. The first result is a 'Google promotion' for 'Try Google Search Console'. The subsequent results are from 'TryHackMe' and include:

- Learn Cyber Security | TryHackMe Cyber Training**
For beginners looking to start out in cybersecurity, **TryHackMe is the place to go**. Log in, pick a learning path, launch the tasks and you're underway. The ... [Read more](#)
- TryHackMe | Affiliate Programme**
We're a gamified, **hands-on cyber security training platform** that you can access through your browser.
- TryHackMe | Hacktivities**
Offensive and defensive cyber security training with hands-on exercises and labs. Hack machines, investigate attacks, and build real-world skills through ...
- Leaderboards**
We're a gamified, **hands-on cyber security training platform** that you can access through your browser.

Figure 4: Google dork using the `site:` operator

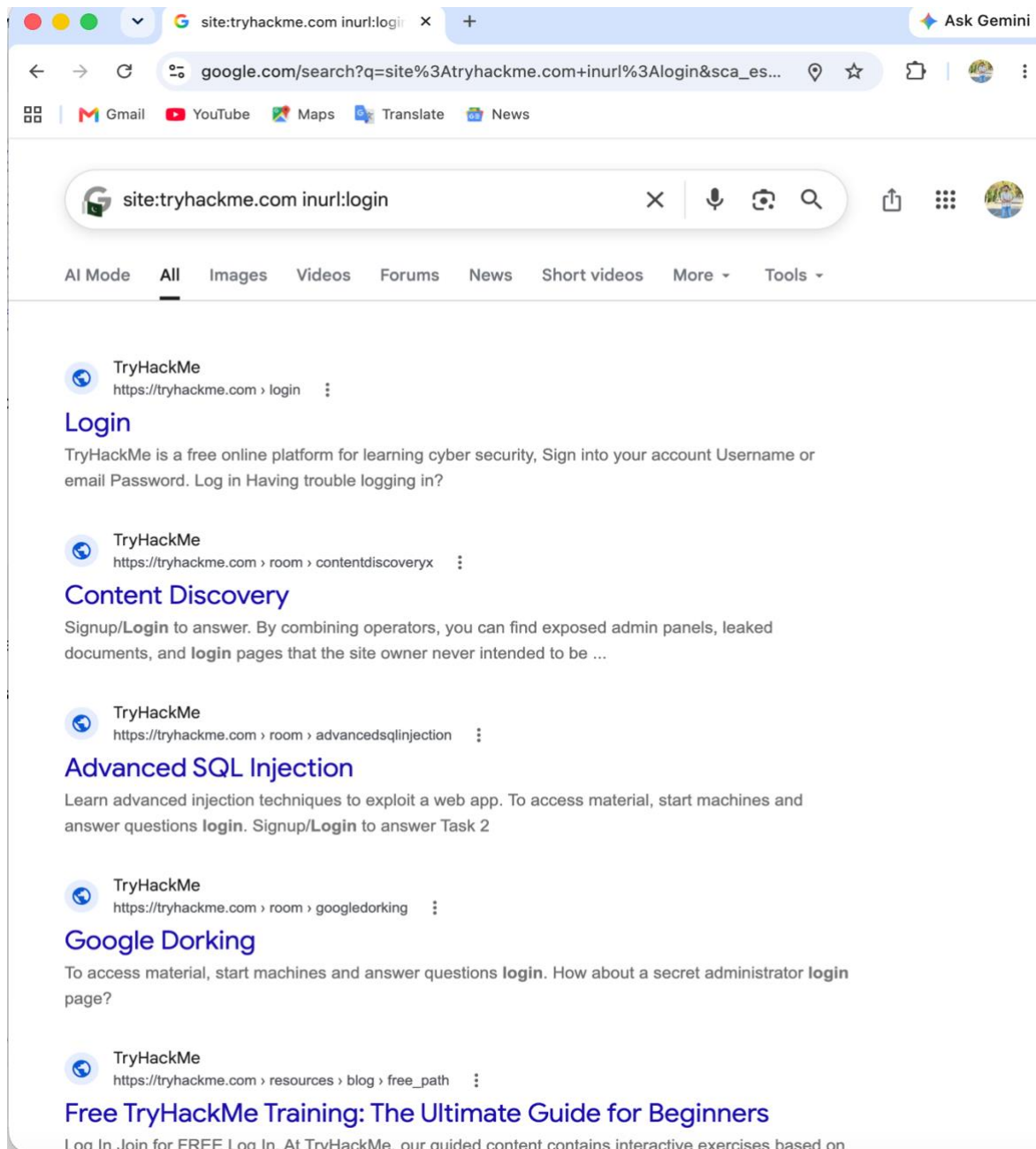


Figure 5: Google dork identifying an indexed login page

5.4 Social Media OSINT

Publicly available social media information was reviewed as part of the OSINT process. A Google search for TryHackMe's LinkedIn presence identified its public LinkedIn profile. The search results describe TryHackMe as an online, cloud-based cybersecurity training platform and also show its public jobs presence. Social media reconnaissance can provide useful organizational information without directly interacting with the target's infrastructure.

The screenshot shows a Google search for "TryHackMe LinkedIn". The search bar at the top contains the text "TryHackMe LinkedIn" with a magnifying glass icon to the right. Below the search bar, there are tabs for "All Mode", "All", "Images", "News", "Forums", "Videos", "Short videos", "More", and "Tools". The "All" tab is selected. The search results display three items:

- LinkedIn · TryHackMe**: 813.4K+ followers. The profile picture is the LinkedIn logo. The title "TryHackMe" is in blue. The description says: "TryHackMe | 814315 followers on LinkedIn. TryHackMe is an online, cloud-based, cyber security training platform used by individuals and academics alike."
- Jobs at TryHackMe**: TryHackMe | 805427 followers on LinkedIn. TryHackMe is an ... (truncated). There is a right arrow icon.
- More results from linkedin.com »**

Below the "More results from linkedin.com »" link, there are two more results:

- LinkedIn · TryHackMe**: 813.4K+ followers. The profile picture is the LinkedIn logo. The title "TryHackMe" is in blue. The description says: "TryHackMe takes the pain out of learning and teaching Cybersecurity. Our platform makes it a comfortable experience to learn by designing prebuilt courses which ... [Read more](#)"
- TryHackMe**: <https://tryhackme.com> > login. The profile picture is a blue circle with a white globe icon. The title "Login" is in blue. The description says: "TryHackMe is a free online platform for learning cyber security, using hands-on exercises and labs, all through your browser!"

Figure 6: Public LinkedIn information identified during social media OSINT

#	OSINT Finding	Source
1	Target domain identified as <code>tryhackme.com</code>	WHOIS
2	Domain registrar is NameCheap, Inc.	WHOIS
3	Domain was created on July 5, 2018	WHOIS
4	Cloudflare name servers are used	WHOIS
5	<code>auth.tryhackme.com</code> was identified	CT Logs
6	<code>careers.tryhackme.com</code> was identified	CT Logs
7	<code>vpn.tryhackme.com</code> was identified	CT Logs
8	<code>labs.tryhackme.com</code> was identified	CT Logs
9	A public login page was indexed by Google	Google Dorking
10	A public LinkedIn presence was identified	Social Media

Q6. Subdomain Enumeration

Subdomain enumeration was performed on the selected target `tryhackme.com` using Subfinder. Subfinder is a passive subdomain discovery tool that collects publicly available information from multiple sources. The enumeration identified numerous subdomains associated with the target domain.

Command Used:

subfinder -d tryhackme.com

Discovered Subdomains

#	Subdomain
1	vpn.vm.tryhackme.com
2	remote-eu-1.tryhackme.com
3	external.assets.tryhackme.com
4	status.tryhackme.com
5	setup.auth.tryhackme.com
6	auth.tryhackme.com
7	insights-proxy-worker.tryhackme.com
8	lp.tryhackme.com
9	snapshot-costs.vm.tryhackme.com
10	squawker-vpn.vm.tryhackme.com


```
(zaid@kali)-[~]
$ subfinder -d tryhackme.com

projectdiscovery.io

[INF] Current subfinder version v2.14.0 (outdated)
[INF] Loading provider config from /home/zaid/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for tryhackme.com
novnc.cell-prod-ap-south-1b.vm.tryhackme.com
novnc.cell-prod-eu-central-1a.vm.tryhackme.com
cell-prod-eu-central-1b.vm.tryhackme.com
novnc.cell-prod-eu-west-1b.vm.tryhackme.com
app.lb-architect.tryhackme.com
reverse-proxy.cell-prod-eu-west-3c.vm.tryhackme.com
novnc.cell-prod-us-east-1b.vm.tryhackme.com
reverse-proxy.cell-prod-us-west-2a.vm.tryhackme.com
costra.vm.tryhackme.com
vpn.vm.tryhackme.com
remote-eu-1.tryhackme.com
blog.vm.tryhackme.com
reverse-proxy.cell-prod-eu-west-1a.vm.tryhackme.com
cell-prod-us-west-2a.vm.tryhackme.com
cell-prod-us-west-2c.vm.tryhackme.com
external.assets.tryhackme.com
status.tryhackme.com
access.vm.tryhackme.com
novnc.cell-prod-ap-south-1a.vm.tryhackme.com
cell-prod-eu-west-3c.vm.tryhackme.com
cell-prod-us-east-1a.vm.tryhackme.com
reverse-proxy.cell-prod-us-east-1c.vm.tryhackme.com
squawker-vpn.vm.tryhackme.com
setup.auth.tryhackme.com
cell-prod-eu-west-1b.vm.tryhackme.com
reverse-proxy.cell-prod-eu-west-1b.vm.tryhackme.com
novnc.cell-prod-eu-west-3c.vm.tryhackme.com
snapshot-costs.vm.tryhackme.com
auth.tryhackme.com
insights-proxy-worker.tryhackme.com
novnc.cell-prod-us-east-1a.vm.tryhackme.com
cell-prod-us-east-1b.vm.tryhackme.com
novnc.cell-prod-us-west-2a.vm.tryhackme.com
status-api.vm.tryhackme.com
lp.tryhackme.com
cell-prod-ap-south-1b.vm.tryhackme.com
```

Figure 7: Subdomain enumeration of tryhackme.com using Subfinder

Result:

The Subfinder scan successfully identified more than the required 10 subdomains. These discovered assets provide information about the target's publicly visible attack surface and can be used to understand the organization's external infrastructure.

Q7. Attack Surface Diagram

An attack surface diagram was created using the assets and subdomains discovered during passive reconnaissance and Subfinder enumeration. The diagram shows how the main `tryhackme.com` domain is related to publicly discoverable authentication, platform, virtual machine, infrastructure, proxy, and other services. Mapping these assets helps security analysts understand the externally visible attack surface and identify systems that may require further security assessment.

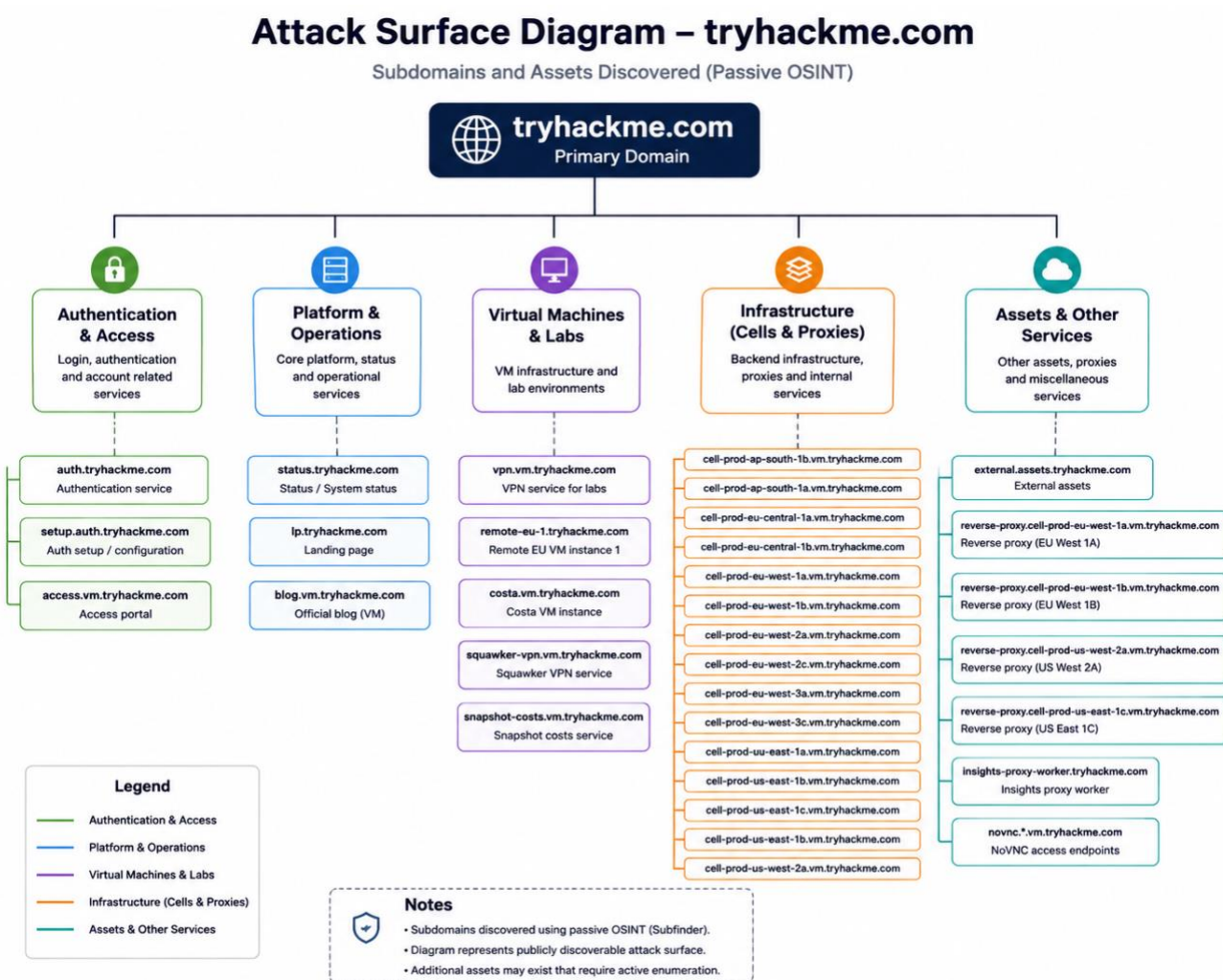


Figure 8: Attack Surface Diagram of tryhackme.com based on discovered subdomains

The diagram demonstrates that the target has multiple publicly discoverable services and subdomains. These assets increase the overall attack surface and should be properly monitored, updated, and protected using appropriate access controls and security configurations.

Phase 3: Enumeration & Scanning.

Q8. Nmap Scan Types and Comparison

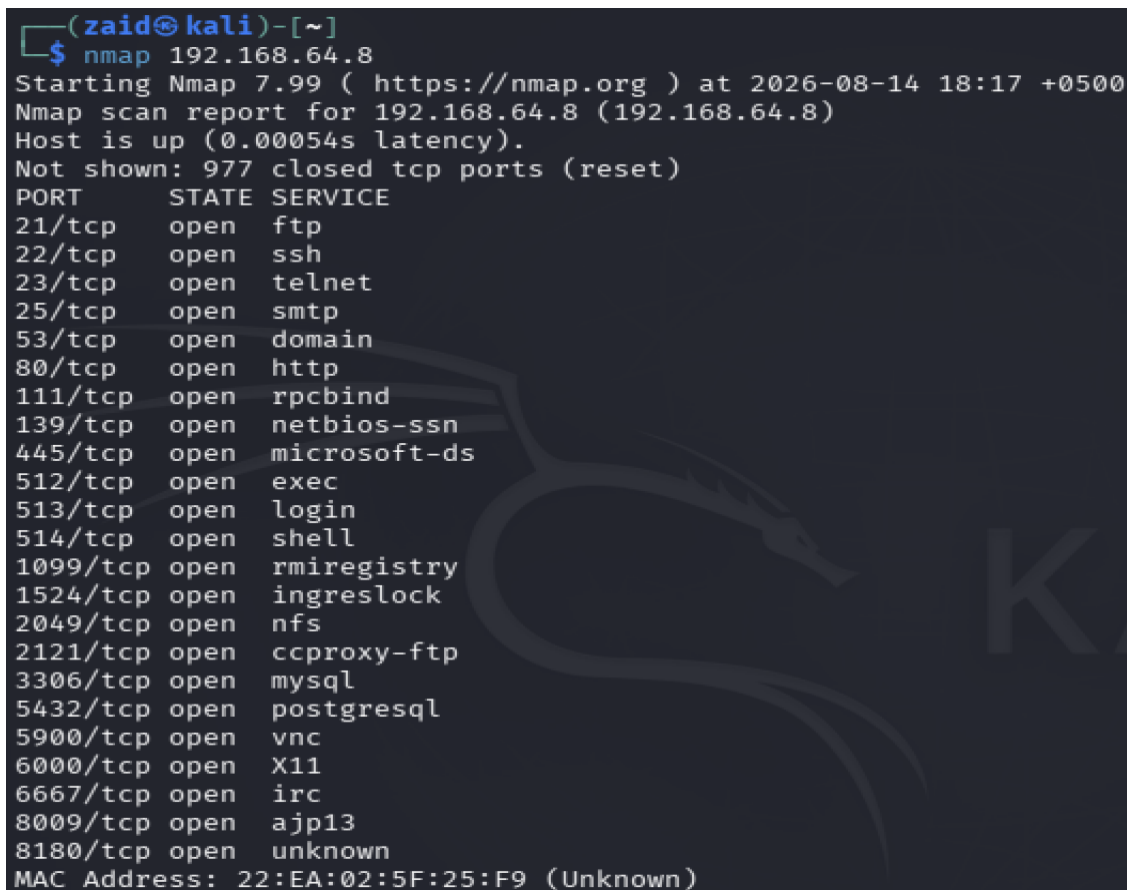
To perform network enumeration and scanning, multiple Nmap scan types were conducted against the authorized **Metasploitable 2 lab machine** with IP address **192.168.64.8**. The purpose was to identify open ports, running services, service versions, operating system information, and the overall attack surface of the target.

1. Basic Nmap Scan

Command:

```
nmap 192.168.64.8
```

The basic Nmap scan was performed to identify commonly used open TCP ports on the target system. The scan showed multiple open services including FTP (21), SSH (22), Telnet (23), HTTP (80), SMB (139/445), MySQL (3306), PostgreSQL (5432), VNC (5900), and others.



```
(zaid@kali)-[~]
$ nmap 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:17 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.00054s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 22:EA:02:5F:25:F9 (Unknown)
```

Figure 1: Basic Nmap scan showing open ports on Metasploitable 2.

2. Service Version Detection Scan

Command:

```
nmap -sV 192.168.64.8
```

The `-sV` scan was used to identify the services and their versions running on open ports. It detected services such as **vsftpd 2.3.4**, **OpenSSH 4.7p1**, **Apache HTTP Server 2.2.8**, **MySQL 5.0.51a**, and **PostgreSQL 8.3.x**.

```
(zaid@kali)-[~]
$ nmap -sV 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:19 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 22:EA:02:5F:25:F9 (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.05 seconds
```

Figure 2: Nmap service and version detection scan.

3. Operating System Detection Scan

Command:

```
sudo nmap -O 192.168.64.8
```

The `-O` option was used for operating system detection. Nmap identified the target as a **Linux 2.6.X** system, with OS details indicating approximately **Linux 2.6.9–2.6.33**. The network distance was reported as **1 hop**.

```
(zaid@kali)-[~]
$ sudo nmap -O 192.168.64.8
[sudo] password for zaid:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:23 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 22:EA:02:5F:25:F9 (Unknown)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.53 seconds
```

Figure 3: Nmap operating system detection results.

4. Aggressive Scan

Command:

```
sudo nmap -A 192.168.64.8
```

The aggressive scan provided the most detailed information. It combined service/version detection, operating system detection, default Nmap scripts, and traceroute information. It also revealed additional information about services such as FTP, SSH, Apache, Samba, MySQL, PostgreSQL, VNC, IRC, and Apache Tomcat.

```
└─$ sudo nmap -A 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:24 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.64.7
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O
COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
ETRNL, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-08-14T13:26:15+00:00; 0s from scanner time.
|_sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_
53/tcp    open  domain       ISC BIND 9.4.2
```

Figure 4: Nmap aggressive scan showing detailed service information.

```
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-08-14T09:26:04-04:00
|_clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:
|   <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   1.85 ms  192.168.64.8 (192.168.64.8)

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 77.11 seconds
```

Figure 5: Aggressive scan showing OS detection, SMB information, and traceroute

5. Full TCP Port Scan

Command:

```
sudo nmap -p- 192.168.64.8
```

The `-p-` scan was used to scan all **65,535 TCP ports**. It identified additional open ports that were not included in the default scan, including ports **3632, 6697, 8787, 45828, 47894, 49986, and 53087**.

```
(zaid@kali)-[~]
$ sudo nmap -p- 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 18:32 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.0013s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
45828/tcp open  unknown
47894/tcp open  unknown
49986/tcp open  unknown
53087/tcp open  unknown
MAC Address: 22:EA:02:5F:25:F9 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 2.90 seconds
```

Figure 6: Full TCP port scan of Metasploitable 2.

Scan Comparison

Scan Type	Command	Main Purpose	Result
Basic Scan	nmap 192.168.64.8	Find common open ports	Multiple open ports discovered
Version Scan	nmap -sV 192.168.64.8	Detect service versions	Identified exact versions of major services
OS Detection	sudo nmap -O 192.168.64.8	Identify operating system	Linux 2.6.X detected

Aggressive Scan	sudo nmap -A 192.168.64.8	Detailed enumeration	Most detailed scan
Full Port Scan	sudo nmap -p- 192.168.64.8	Scan all TCP ports	Additional open ports discovered

Conclusion

Among the scans performed, the **Aggressive Scan (-A)** provided the most detailed information, because it combined OS detection, service/version detection, Nmap scripts, and traceroute. The **Full Port Scan (-p-)** provided the widest port coverage, as it scanned all 65,535 TCP ports and discovered additional open ports.

Q9: Service and Version Identification & Banner Grabbing

Objective:

The purpose of this task was to identify the exact services and versions running on the open ports of the Metasploitable 2 lab machine and perform banner grabbing on at least one service.

Target IP: 192.168.64.8

Service and Version Detection

The following command was used:

```
nmap -sV 192.168.64.8
```

The `-sV` option enables service and version detection. The scan identified multiple services running on the target system.

Port	Service	Detected Version
21	FTP	vsftpd 2.3.4
22	DNS	OpenSSH 4.7p1 Debian 8ubuntu1
23	Telnet	Linux telnetd
25	SMTP	Postfix smtpd
53	DNS	ISC BIND 9.4.2

80	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/445	SMB	Samba smbd 3.X–4.X / Samba 3.0.20-Debian
1099	Java RMI	GNU Classpath rmiregistry
1524	Bindshell	Metasploitable root shell
2049	NFS	NFS 2–4
2121	FTP	ProFTPD 1.3.1
3306	MySQL	MySQL 5.0.51a-3ubuntu5
5432	PostgreSQL	PostgreSQL DB 8.3.0–8.3.7
5900	VNC	VNC protocol 3.3
6667	IRC	UnrealIRCd
8009	AJP13	Apache Jserv Protocol v1.3
8180	HTTP	Apache Tomcat/Coyote JSP engine 1.1

Banner Grabbing

Banner grabbing was performed against the FTP service on port 21 using Netcat:

```
nc 192.168.64.8 21
```

The server returned:

```
220 (vsFTPD 2.3.4)
```

This confirmed that **vsFTPD version 2.3.4** was running on TCP port 21.

```
(zaid@kali)-[~]  
$ nc 192.168.64.8 21  
220 (vsFTPd 2.3.4)  
█
```

Figure: FTP Banner Grabbing Using Netcat

Conclusion

The service/version scan successfully identified the software running on multiple open ports. Banner grabbing further confirmed that the FTP service on port 21 was running **vsFTPd 2.3.4**. These identified versions can be investigated for known vulnerabilities and CVEs during the vulnerability assessment phase.

Q10: Web Application Technology Stack and Relevant OWASP Top 10 Risks

Objective:

The purpose of this task was to identify the technology stack used by the web application hosted on the Metasploitable 2 lab target and identify relevant OWASP Top 10 security categories without exploiting the system.

Target IP: 192.168.64.8

Web Application Identification

The target was accessed through a web browser using:

`http://192.168.64.8`

The Metasploitable 2 web page was successfully accessible. The server provides multiple intentionally vulnerable web applications and services, including **TWiki**, **phpMyAdmin**, **Mutillidae**, **DVWA**, and **WebDAV**.

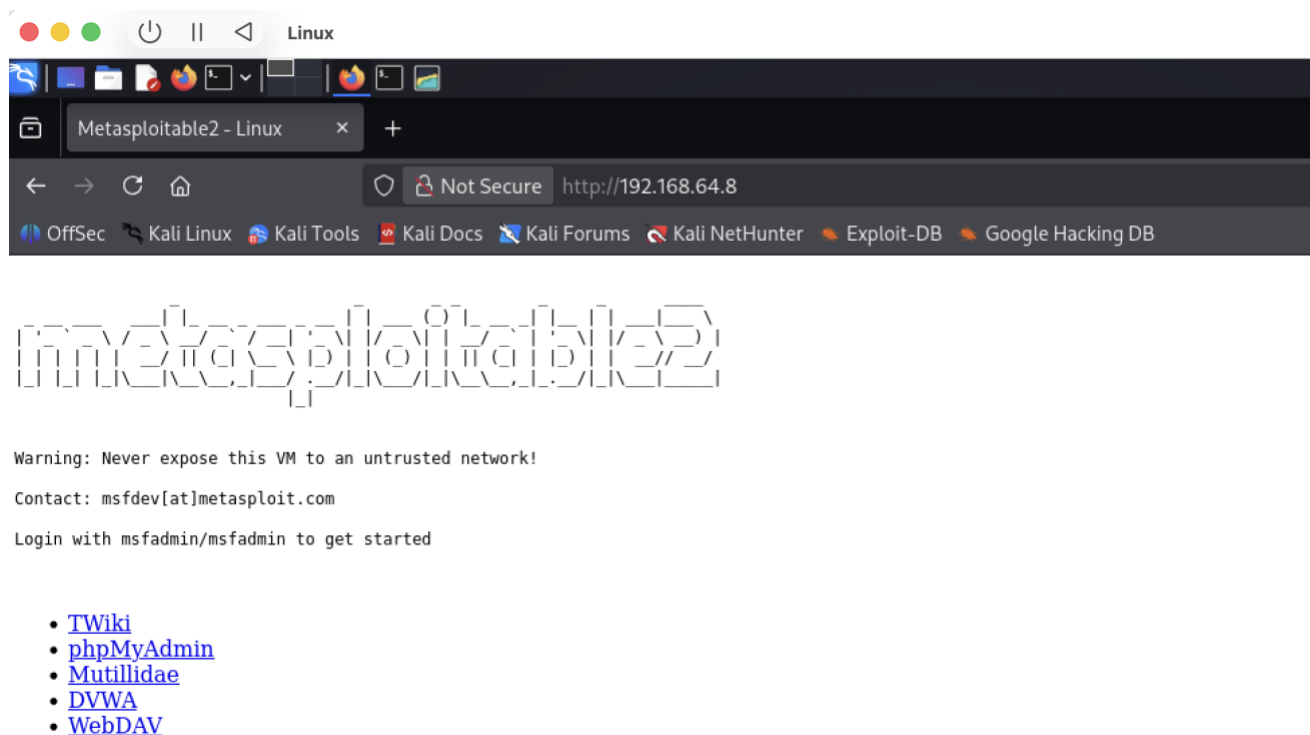


Figure: Metasploitable 2 Web Applications Hosted on the Target

Technology Stack Identification

WhatWeb was used to fingerprint the technologies running on the web server:

```
whatweb http://192.168.64.8
```

The scan identified the following technology stack:

Component	Identified Technology
Operating System	Ubuntu Linux
Web Server	Apache 2.2.8 (Ubuntu)
Programming Language	PHP 5.2.4-2ubuntu5.10
Web Technology	WebDAV
Apache Module	DAV/2
HTTP Response	200 OK

The results indicate that the target uses an **Apache/PHP-based web stack running on Ubuntu Linux**.

```
(zaid@kali)-[~]
$ whatweb http://192.168.64.8
http://192.168.64.8 [200 OK] Apache[2.2.8], Country[RESERVED][ZZ], HTTPServer[Ubuntu Linux][
Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.64.8], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable
2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]

(zaid@kali)-[~]
$
```

Figure: Technology Stack Identification Using WhatWeb

Relevant OWASP Top 10 Categories

Based on the exposed web applications and the observed technology stack, the following OWASP Top 10 categories are particularly relevant for further assessment:

OWASP Category	Relevance
Broken Access Control	Web applications should be reviewed to ensure users cannot access unauthorized resources or functions.
Injection	Applications interacting with databases may be exposed to injection risks if user input is not properly validated.
Security Misconfiguration	Exposed services, WebDAV, server information, and unnecessary functionality may indicate insecure configuration.
Identification and Authentication Failures	Login interfaces should be assessed for weaknesses in authentication and session management.
Vulnerable and Outdated Components	The detected Apache and PHP versions are old and should be checked against known vulnerabilities and CVEs.
Cryptographic Failures	The site was accessed over HTTP and the browser displayed “ Not Secure ,” indicating that traffic was not protected by HTTPS/TLS during this test.

Conclusion

The target hosts multiple web applications and uses an Apache/PHP web stack on Ubuntu Linux. Several OWASP Top 10 categories are relevant to the observed attack surface, particularly **Security Misconfiguration, Vulnerable and Outdated Components, Broken Access Control, Injection, Authentication Failures, and Cryptographic Failures**. No exploitation was performed during this phase.

Phase 4: Vulnerability Assessment

Q11. Match at least 3 discovered services/versions to real CVEs using the NVD database.

During the vulnerability assessment of the Metasploitable 2 target (192.168.64.8), several outdated services were identified. Their versions were compared with vulnerability records available in the National Vulnerability Database (NVD).

1. vsftpd 2.3.4 – CVE-2011-2523

The FTP service was identified as vsftpd 2.3.4. This version is associated with CVE-2011-2523, involving a malicious backdoor that can open a remote shell.

2. Samba 3.0.20 – CVE-2007-2447

The Samba service was identified as version 3.0.20. It is affected by CVE-2007-2447, which can allow remote attackers to execute arbitrary commands under vulnerable configurations.

3. PHP 5.2.4 – CVE-2007-4825

The web server was found running PHP 5.2.4. According to the NVD record shown in your screenshot, CVE-2007-4825 affects PHP 5.2.4 and earlier and involves directory traversal that may bypass `open_basedir` restrictions and potentially allow arbitrary code execution.

NVD - CVE-2011-2523

nvd.nist.gov/vuln/detail/CVE-2011-2523

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST NATIONAL VULNERABILITY DATABASE NVD

VULNERABILITIES

CVE-2011-2523 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector

QUICK INFO

CVE Dictionary Entry:
[CVE-2011-2523](#)

NVD Published Date:
11/27/2019

NVD Last Modified:
06/16/2026

Source:
Red Hat, Inc.

Figure 1: NVD record for CVE-2011-2523

Q12. CVSS Severity Rating and Justification

1. CVE-2011-2523 – vsftpd 2.3.4

CVSS Score: 9.8/10

Severity: Critical

CVSS Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Justification:

This vulnerability is rated Critical because it can be exploited remotely over the network with low attack complexity. No privileges or user interaction are required. Successful exploitation can have a high impact on confidentiality, integrity, and availability of the affected system.



Figure: CVSS 3.1 score for CVE-2011-2523 from NVD

2. CVE-2007-2447 – Samba 3.0.20

CVSS Score: 6.0/10

Severity: Medium

CVSS Version: 2.0

CVSS Vector: (AV:N/AC:M/Au:S/C:P/I:P/A:P)

Justification:

This vulnerability is rated Medium by NVD. It can be exploited remotely over the network, but the CVSS vector indicates medium attack complexity and requires authentication. Successful exploitation can cause partial impact on confidentiality, integrity, and availability.



Figure: CVSS 2.0 score for CVE-2007-2447 from NVD

3. CVE-2007-4825 – PHP 5.2.4

CVSS Score: 7.5/10

Severity: High

CVSS Version: 2.0

CVSS Vector: (AV:N/AC:L/Au:N/C:P/I:P/A:P)

Justification:

This vulnerability is rated High because it can be exploited remotely over the network with low attack complexity and does not require authentication. Successful exploitation can have a partial impact on confidentiality, integrity, and availability.

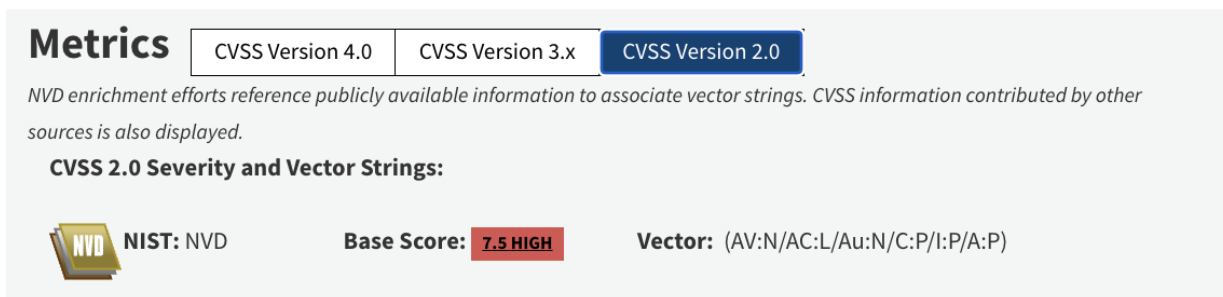


Figure: CVSS 2.0 score for CVE-2007-4825 from NVD

Vulnerability	Service	CVSS	Severity
CVE-2011-2523	vsftpd 2.3.4	9.8	Critical
CVE-2007-2447	Samba 3.0.20	6.0	Medium
CVE-2007-4825	PHP 5.2.4	7.5	High

Q13. Risk Matrix (Likelihood × Impact)

Vulnerability	Likelihood	Impact	Risk Level
CVE-2011-2523 – vsftpd 2.3.4	High	High	Critical

CVE-2007-2447 – Samba 3.0.20	Medium	High	High
CVE-2007-4825 – PHP 5.2.4	High	Medium	High

Risk Assessment:

CVE-2011-2523 presents the highest risk because it can be exploited remotely with low complexity and without authentication. CVE-2007-2447 is considered High risk due to the potential impact of remote command execution, while CVE-2007-4825 is also High risk because it can be exploited remotely without authentication.

Q14. Cryptography and TLS Review

HTTPS/TLS Evaluation

The Nmap scan shows that port 80 (HTTP) is open and running Apache HTTP Server 2.2.8, while port 443 (HTTPS) is closed. Therefore, the target does not correctly use HTTPS/TLS for its web traffic. Communication over HTTP is not encrypted, which means sensitive information transmitted between a client and the server could potentially be exposed. For an e-commerce environment, HTTPS should be enabled with a valid TLS certificate to protect customer information.

Symmetric Encryption

Symmetric encryption uses the **same secret key** for both encryption and decryption. It is fast and suitable for encrypting large amounts of data. Examples include **AES**. In HTTPS/TLS, symmetric encryption is primarily used to protect the actual data transferred during an established secure session.

Asymmetric Encryption

Asymmetric encryption uses a **public key and a private key**. The public key can be shared, while the private key remains secret. It is used for authentication, digital signatures, and establishing secure communication. Examples include **RSA** and **ECC**. In TLS, public-key cryptography is used as part of server authentication and, depending on the cipher suite/protocol version, key establishment.

```
(zaid@kali)-[~]
$ nmap -p 80,443 -sV 192.168.64.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 20:04 +0500
Nmap scan report for 192.168.64.8 (192.168.64.8)
Host is up (0.00092s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
443/tcp   closed https
MAC Address: 22:EA:02:5F:25:F9 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.70 seconds
```

Figure: Nmap scan showing HTTP port 80 open and HTTPS port 443 closed.

Remediation Recommendations

Based on the vulnerability assessment of the Metasploitable 2 lab environment, the following remediation measures are recommended to improve the security posture of Nimbus Retail Co.

1. Upgrade or Remove vsftpd 2.3.4

The vsftpd 2.3.4 service associated with CVE-2011-2523 should be removed or upgraded to a secure and supported version. Unnecessary FTP access should be disabled. Secure alternatives such as SFTP should be considered where file transfer is required.

2. Update Samba Services

The outdated Samba 3.0.20 installation should be upgraded to a currently supported version. Access to SMB ports should be restricted to authorized systems and users only, and unnecessary file shares should be disabled.

3. Upgrade PHP and Web Components

PHP 5.2.4 and other outdated web components should be replaced with supported versions. Regular patch management should be implemented to ensure known vulnerabilities are addressed promptly.

4. Enable HTTPS/TLS

The assessment found HTTP available on port 80 while HTTPS on port 443 was closed. Nimbus Retail Co. should deploy a valid TLS certificate, enable HTTPS, and redirect HTTP traffic to HTTPS to protect sensitive information transmitted between customers and the web server.

5. Reduce the Attack Surface

Multiple network services and ports were found open during Nmap scanning. Services that are not required for business operations should be disabled, and firewall rules should permit access only to necessary services.

6. Strengthen Network Segmentation and Access Control

Web servers, database servers, and employee systems should be separated into appropriate network segments. Access between these segments should follow the principle of least privilege.

7. Establish Continuous Security Management

Regular vulnerability scans, software updates, log monitoring, secure configuration reviews, backups, and periodic security assessments should be performed. Critical vulnerabilities should receive the highest remediation priority.

Priority

Immediate: vsftpd critical vulnerability, HTTPS/TLS, unnecessary exposed services

High: Samba and PHP upgrades

Ongoing: patching, monitoring, access control, backups, and vulnerability assessments

Q15. Incident Response Plan

Scenario:

A critical vulnerability in Nimbus Retail Co.'s environment has been exploited by an attacker, resulting in unauthorized access and theft of customer data. The following incident response process should be followed.

1. Detect

The security team should identify the incident by reviewing firewall, server, authentication, and application logs. Suspicious login attempts, unusual network traffic, unexpected processes, and unauthorized access to customer records should be investigated. The affected systems, compromised accounts, and type of stolen data should be identified and documented.

2. Contain

Immediately isolate compromised systems from the network to prevent further unauthorized access. Disable compromised user accounts, block malicious IP addresses, and restrict access to affected services. Evidence and logs should be preserved before making major changes so that the incident can be investigated properly.

3. Eradicate

Identify and remove the root cause of the compromise. Patch the exploited vulnerability, remove malicious files or unauthorized accounts, reset compromised credentials, and update vulnerable software. All affected systems should be scanned to ensure that no attacker persistence or malware remains.

4. Recover

Restore affected systems from trusted backups and return services to operation gradually. Verify that security patches and configuration changes are working correctly before reconnecting systems to the production network. Continue monitoring logs and network activity for signs of renewed malicious activity.

Post-Incident Actions:

Nimbus Retail Co. should document the incident, determine its business impact, review security

controls, and improve monitoring and vulnerability management. Relevant management, customers, and authorities should be notified where required by applicable policies or laws.

Q16. Executive Summary

Executive Summary

A security assessment was conducted on the simulated Nimbus Retail Co. environment to evaluate its overall security posture before the launch of its e-commerce platform. The assessment included network scanning, service identification, vulnerability analysis, web security review, and risk assessment.

The assessment identified several significant security weaknesses. Multiple unnecessary and outdated network services were accessible, increasing the overall attack surface. Three vulnerabilities were selected for detailed assessment, including weaknesses associated with vsftpd 2.3.4, Samba 3.0.20, and PHP 5.2.4. The most serious finding was associated with vsftpd 2.3.4 and received a Critical severity rating.

The **top three security risks** identified were:

1. **Critical FTP service vulnerability:** An outdated FTP service presents a serious risk of unauthorized system access.
2. **Vulnerable and outdated software:** Older Samba and PHP components expose the organization to known security weaknesses.
3. **Unencrypted web communication:** The web server uses HTTP while HTTPS is unavailable, meaning web traffic is not adequately protected in transit.

If similar weaknesses existed in a production e-commerce environment, successful attacks could lead to unauthorized access, customer data exposure, service disruption, financial losses, and reputational damage.

Nimbus Retail Co. should prioritize remediation before launching the platform. Critical vulnerabilities should be addressed immediately, outdated software should be upgraded or replaced, unnecessary services and ports should be disabled, and HTTPS/TLS should be properly implemented. Regular vulnerability assessments, patch management, network segmentation, access controls, logging, and continuous security monitoring should also be established.

Overall, the assessed environment currently represents a **high security risk** and would require significant security improvements before being considered suitable for handling sensitive customer and business information.